

Vulnerability Assessment Report

1st January 20XX

System Description

The server hardware consists of a powerful CPU processor and 128GB of memory. It runs on the latest version of Linux operating system and hosts a MySQL database management system. It is configured with a stable network connection using IPv4 addresses and interacts with other servers on the network. Security measures include SSL/TLS encrypted connections.

Scope

The scope of this vulnerability assessment relates to the current access controls of the system. The assessment will cover a period of three months, from June 20XX to August 20XX. [NIST SP 800-30 Rev. 1](#) is used to guide the risk analysis of the information system.

Purpose

This vulnerability assessment focuses on evaluating the security of our main database server, which holds critical customer and business data. The server is vital to daily operations and supports access to important client and financial information. Given the risks of ransomware attacks, insider threats, and potential system outages, it's crucial to secure this server to prevent data loss, protect customer privacy, and maintain business continuity. A compromise or outage could severely disrupt operations, damage our reputation, and lead to legal or financial consequences.

Risk Assessment

Threat source	Threat event	Likelihood	Severity	Risk
Competitor	Obtain sensitive information via exfiltration	1	3	3
Hacker	Deploy ransomware to encrypt company data and demand payment	2	3	6
Natural disaster	Cause data center outage resulting in service downtime	1	2	2

Approach

Risks considered the data storage and management methods of the business. The likelihood of a threat occurrence and the impact of these potential events were weighed against the risks to day-to-day operational needs.

The chosen threat sources and events are significant business risks for the following reasons:

- **Competitor obtaining sensitive information:** A competitor could gain access to confidential business data in a device. This is unlikely (Likelihood: 1) but has a severe impact (Severity: 3) since it could expose proprietary information and damage the company's competitive standing.
- **Hacker deploying ransomware:** A hacker could launch a ransomware attack to encrypt company data and demand payment. This scenario is moderately likely (Likelihood: 2) and highly severe (Severity: 3) because it could halt operations, result in financial loss, and lead to significant data breaches.
- **Natural disaster causing data center outage:** A natural event such as a power failure or flood could render the database server unavailable. While the likelihood is low (Likelihood: 1), the impact is moderate (Severity: 2) since it could cause temporary downtime and delay access to business-critical systems.

Remediation Strategy

Implementation of authentication, authorization, and auditing mechanisms to ensure that only authorized users access the database server. This includes using strong passwords, role-based access controls, and multi-factor authentication to limit user privileges. Encryption of data in motion using TLS instead of SSL. IP allow-listing to corporate offices to prevent random users from the internet from connecting to the database.

To mitigate these identified risks, we propose the following security controls:

- **Implement Role-Based Access Control (RBAC):** Restrict user permissions based on job responsibilities to ensure employees and administrators only have access to the data and systems necessary for their roles.
- **Apply the Principle of Least Privilege:** Continuously review and adjust user access to minimize exposure of sensitive information and prevent unauthorized actions.
- **Enforce Multi-Factor Authentication (MFA):** Require users to verify their identity through multiple factors, such as a password and a one-time verification code or hardware token, before accessing the database.

- **Strengthen Monitoring and Logging:** Utilize the Authentication, Authorization, and Accounting (AAA) framework to monitor user activity, enforce access policies, and maintain detailed audit logs for accountability.

By implementing these strategies, the organization can significantly reduce the possibility of security incidents.